Title: Creating Strong Passwords at NorthTec

Author: NorthTec Security Team

Version: 1.0

Created: 2023-11-08

Visibility: INTERNAL — NorthTec employees only

Creating Strong Passwords at NorthTec

NorthTec Security Team

Version 1.0 — 2023-11-08

INTERNAL — For NorthTec employees only

Table of Contents

1. Purpose and scope

2. Password policy

3. Examples: weak vs strong

4. Approved tools (password managers, MFA)

5. Password reset procedure

6. Developer guidance: secrets handling

7. Detecting and reporting exposed credentials

8. FAQ

9. Revision history

1. Purpose and scope

This guide explains NorthTec's expectations for creating, storing and rotating passwords used to access company systems, services and development environments. It applies to all NorthTec employees, contractors and vendors who access internal resources. The goal is to reduce risk from weak or reused credentials and to provide clear, actionable guidance on incident reporting and remediation.

2. Password policy

- Minimum length: 12 characters for standard user accounts; 16+ for privileged accounts.

- Composition guidance: prioritize length and use of passphrases. When required by an application, include mixed character types.

- Prohibited elements:

  - Do not use your username, account name, company name, or obvious sequences (e.g., 123456, qwerty).

  - Do not reuse corporate passwords across multiple services or use the same password for personal accounts.

- Expiration: passwords are changed on risk-based triggers (suspected exposure, role change, or confirmed compromise). Routine forced rotation is not typical for low-risk accounts.

- Account lockout: repeated failed sign-in attempts will trigger account lockout per IT thresholds.

- Privileged accounts: must use unique credentials stored in the approved secrets manager and require additional access controls.

3. Examples: weak vs strong

Weak patterns (avoid):

- shortcommon

- firstname123

- Password123

Stronger approaches (recommended):

- Use a long passphrase of unrelated words (e.g., correct horse battery staple-style; shown here as an illustration only).

- Use a password manager to generate and store unique, randomized passwords per site.

- Consider adding a short, memorable suffix or prefix if needed for systems that require specific characters.

Important: Do not share passwords via email, chat, or commit them to source control. Do not store plaintext passwords in documentation.

4. Approved tools (password managers, MFA)

- Use the company-approved password manager for storing credentials. Enable the enterprise vault and SSO integration where available.

- Enforce multi-factor authentication (MFA) for remote access, cloud consoles, admin portals and any system with elevated privileges. Approved MFA options: company SSO with TOTP, hardware tokens for privileged access.

- Contact IT if you require exceptions for legacy systems; approvals are time-limited and must be recorded.

5. Password reset procedure

If you forget your password or suspect compromise:

1. Use the official reset portal: https://auth.northtec.corp/reset (internal only).

2. Complete the secondary verification step (email challenge or SSO).

3. If self-service fails, open a ticket to IT Security with subject: "Password Reset — [Your Name]" and include contact details for identity verification.

4. For privileged accounts, IT will require manager confirmation and additional identity checks prior to reset.

Notes:

- Do not accept password reset requests over unsolicited phone calls or direct messages.

- After any reset following suspected compromise, rotate credentials for any services where reuse occurred.

6. Developer guidance: secrets handling

- Never commit plaintext credentials, API keys, tokens or secrets to version control.

- Use environment variables and an approved secrets manager for runtime secrets.

- For testing, use clearly labeled test accounts and vault-stored secrets with short expiration.

- Run the repository through the company secrets scanner before publishing externally.

- If you discover secrets in public repos, follow the reporting steps immediately.

7. Detecting and reporting exposed credentials

Indicators of exposure:

- Publicly accessible files listing usernames, references to test accounts, or any mention of NorthTec-specific credentials.

- Commit messages or code comments that include account identifiers or references to credentials.

When you find a suspected exposure:

1. Do not download or exfiltrate files unless explicitly authorized by Security.

2. Record the URL and page title for reporting (a screenshot is acceptable for context).

3. Submit an incident report to security@northtec.example with subject "Potential Credential Exposure", include the URL, a brief description and any immediate observations.

Security will triage the report, advise containment steps (temporary holds or forced resets) and coordinate remediation.

8. FAQ

Q: Should I routinely change my password?

A: Change when prompted by IT, when prompted by the system, or if you suspect compromise. Routine frequent rotation is not required unless risk dictates it.

Q: Can I use a personal password manager for work credentials?

A: No. Use the company-approved manager to ensure credentials can be audited and recovered as needed.

Q: I found a paste mentioning NorthTec accounts — what do I do?

A: Do not upload or publish the content. Report the URL to security@northtec.example and include a brief description. Security will advise next steps.

9. Revision history

v1.0 — 2023-11-08 — Initial publication (NorthTec Security Team)